

Exchange Online Security Review Lab

Maple Equity Lending (MEL)

Scenario

Maple Equity Lending is a Canadian private mortgage lender that uses Microsoft 365 Exchange Online for employee email. Employees exchange mortgage applications, tax documents, bank statements, credit reports, and other confidential customer information by email. I was asked to perform a security review of Exchange Online to identify risks and recommend improvements.

Objectives

- Review the security of Exchange Online.
- Identify risks that could affect email security.
- Evaluate current security controls.
- Recommend improvements based on industry best practices.

Scope

Included: Exchange Online, mailboxes, authentication, mailbox permissions, email forwarding, anti-spam, anti-phishing, auditing, and administrative accounts.

Excluded: SharePoint, OneDrive, Microsoft Teams, endpoints, and Azure infrastructure.

Important Assets

- Customer emails
- Mortgage applications
- Financial statements
- Credit reports
- Executive communications
- Internal company email

Biggest Threats

- Business Email Compromise (BEC)
- Phishing attacks
- Credential theft
- Email spoofing
- Malicious inbox rules
- Insider threats
- Accidental disclosure of sensitive information

Current Environment

Approximately 60 employees use Microsoft 365 Business Premium with Exchange Online, Outlook, remote access, and Microsoft Defender for Office 365.

How I Performed the Review

1. Reviewed authentication controls.
2. Reviewed administrator access.
3. Reviewed mailbox security settings.
4. Reviewed email protection policies.

- 5. Reviewed logging and auditing.
- 6. Reviewed mailbox permissions and forwarding.

Findings and Recommendations

1. MFA Not Enabled for All Users

Risk: Some users do not use Multi-Factor Authentication (MFA).

Recommendation: Enable MFA for every employee, especially administrators and executives.

2. Legacy Authentication Enabled

Risk: Older authentication methods increase the risk of password attacks.

Recommendation: Disable legacy authentication protocols.

3. External Email Forwarding Allowed

Risk: Employees can automatically forward company email to personal accounts.

Recommendation: Block automatic external forwarding unless approved.

4. Mailbox Auditing Not Enabled Everywhere

Risk: Some mailboxes do not have auditing enabled, making investigations more difficult.

Recommendation: Enable mailbox auditing for every mailbox.

5. Too Many Exchange Administrators

Risk: More administrators have Exchange permissions than necessary.

Recommendation: Apply least privilege and review administrator access regularly.

6. Weak Anti-Phishing Protection

Risk: Executive impersonation protection is not fully configured.

Recommendation: Strengthen anti-phishing policies and enable impersonation protection.

7. No Regular Mailbox Permission Reviews

Risk: Users may still have unnecessary access to shared or executive mailboxes.

Recommendation: Review mailbox permissions every quarter.

8. No Data Loss Prevention (DLP)

Risk: Sensitive customer information can be emailed outside the company.

Recommendation: Implement DLP policies to protect confidential information.

Risk Summary

Risk	Rating
MFA not enabled	Critical
Legacy authentication	Critical
External forwarding	Critical
Missing mailbox auditing	High
Too many Exchange admins	High
Weak anti-phishing	Critical
Missing DLP	Critical

Mailbox permissions	High
---------------------	------

Frameworks Referenced

Recommendations align with NIST Cybersecurity Framework (CSF) 2.0, COBIT, ISO/IEC 27001, and CIS Controls.

Priority Actions

1. Enforce MFA for all users.
2. Disable legacy authentication.
3. Block external auto-forwarding.
4. Enable mailbox auditing.
5. Reduce Exchange Administrator privileges.
6. Improve anti-phishing protection.
7. Implement DLP policies.
8. Review mailbox permissions quarterly.

Abbreviations

Abbreviation	Meaning
MFA	Multi-Factor Authentication
BEC	Business Email Compromise
DLP	Data Loss Prevention
PII	Personally Identifiable Information
RBAC	Role-Based Access Control
SIEM	Security Information and Event Management
NIST	National Institute of Standards and Technology
CSF	Cybersecurity Framework
COBIT	Control Objectives for Information and Related Technology
ISO	International Organization for Standardization

Conclusion

The review identified several opportunities to improve Exchange Online security. The highest priorities are enabling MFA, disabling legacy authentication, restricting external forwarding, improving anti-phishing protection, enabling mailbox auditing, and implementing DLP controls to reduce the risk of email compromise and data leakage.